

Basic SECURITY ASSESSMENT REPORT

Domain: worldpublicationsawards.com

Date: March 1, 2026

IP: 198.187.31.182

Prepared For: World Publications AwardsAssessment

Type: External Vulnerability Scan

Report ID: WPA-SEC-20260302-001

1. EXECUTIVE SUMMARY

This report presents the findings of a comprehensive external security assessment conducted on **worldpublicationsawards.com**.

The assessment identified several strong security configurations, particularly in SSL/TLS implementation and infrastructure stability. However, multiple critical and high-severity vulnerabilities were discovered that require immediate remediation.

Overall Security Rating: 69/100 (Grade: D+) – Needs Improvement

Immediate attention is required for:

- Missing critical security headers
- Session cookie configuration flaw
- Exposed sensitive database file

2. POSITIVE FINDINGS

2.1 Secure SSL/TLS Configuration

- TLS 1.2 and TLS 1.3 enabled (deprecated protocols disabled)
- Strong cipher suites (AES-GCM and ChaCha20-Poly1305 only)
- TLS Fallback SCSV supported (prevents downgrade attacks)
- Compression disabled (not vulnerable to CRIME)
- Not vulnerable to Heartbleed
- Valid SSL certificate issued by Sectigo
- Certificate valid until April 2026
- SHA256withRSA signature
- 2048-bit RSA key strength

Assessment: Excellent SSL/TLS configuration.

2.2 Secure Server Configuration

- No CGI vulnerabilities detected
- No exposed .git/ directories
- TRACE/TRACK HTTP methods disabled
- No shellshock vulnerability detected
- No open SMTP relay
- No exposed default admin panels
- Rate limiting behavior observed

Assessment: Good baseline server hardening.

2.3 Web Application Protections

- No reflected XSS detected
- No DOM-based XSS detected
- No stored XSS detected

Assessment: Basic XSS protections appear effective.

2.4 Infrastructure Security

- LiteSpeed web server in use
- No anonymous email relay detected
- Administrative interfaces not publicly listed
- No obvious DoS weakness observed

3. NEGATIVE FINDINGS (REQUIRING REMEDIATION)

3.1 CRITICAL: Missing Security Headers

The following security headers are not implemented:

Missing Header	Risk	Recommended Remediation
X-Frame-Options	Clickjacking attacks	Add X-Frame-Options: DENY or SAMEORIGIN
X-Content-Type-Options	MIME-sniffing attacks	Add X-Content-Type-Options: nosniff
Content-Security-Policy	Increased XSS risk	Implement strict CSP policy
Referrer-Policy	Referrer data	Add Referrer-Policy: strict-origin-when-

	leakage	cross-origin
Permissions-Policy	Browser feature abuse	Restrict camera/mic/geolocation APIs

Impact: Increased vulnerability to clickjacking, XSS, and data leakage.

Priority: Immediate

3.2 CRITICAL: Session Management Flaw

Issue:

PHPSESSID cookie created without HttpOnly flag.

Risk:

Session hijacking via XSS — JavaScript can access the session cookie.

Impact:

Attackers can steal session IDs and impersonate users.

Remediation:

Enable in php.ini:

```
session.cookie_httponly = 1
```

Priority: Immediate

3.3 HIGH: Information Disclosure

Server headers reveal:

- Server: LiteSpeed
- X-Powered-By: PHP/8.2.30

Risk:

Enables targeted exploitation based on known vulnerabilities.

Remediation:

- Set `expose_php = off`
- Hide or modify server signature
- Apply server hardening best practices

Priority: High

3.4 HIGH: Exposed Sensitive File

File Detected: `/users.sql`

Risk:

Potential database backup exposure.

Impact:

Complete database compromise possible (credentials, user data).

Remediation:

- Remove file immediately
- Block `.sql` access via `.htaccess`
- Store backups outside web root

Priority: Immediate

3.5 HIGH: Exposed Administrative Paths

Accessible:

- `/admin/`
- `/login.php`

Risk:

Brute force and credential stuffing attacks.

Remediation:

- Move admin to non-standard path
- Implement IP whitelisting
- Add CAPTCHA
- Enforce login rate limiting

Priority: High

3.6 MEDIUM: CSRF Vulnerabilities

Forms lacking CSRF protection found on:

- `/`
- `/login.php`
- `/register.php`
- `/contact.php`

Risk:

Cross-Site Request Forgery attacks.

Impact:

Attackers can force unauthorized actions.

Remediation:

Implement CSRF tokens on all state-changing forms.

Priority: Medium

3.7 MEDIUM: Open Ports Exposure

Port	Service	Risk
21	FTP	Cleartext credentials
26	RSFTP	Unusual service
53	DNS	Zone transfer risk
465/587	SMTP	Email exposure

Remediation:

- Disable FTP; use SFTP
- Restrict access via firewall rules
- Justify/remove unnecessary services

Priority: Medium

3.8 LOW: No HSTS Enforcement

Initial connection occurs over HTTP before redirect.

Risk:

Man-in-the-middle attack during first connection.

Remediation:

Implement HSTS header:

Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

3.9 LOW: FTP Service Running

Port 21 open with FTP detected.

Risk:

Cleartext credential transmission.

Remediation:

Replace FTP with SFTP or FTPS.

3.10 LOW: Missing robots.txt

/robots.txt returns 404.

Risk:

Search engines may index sensitive paths.

Remediation:

Create robots.txt file to control crawler access.

4. RISK SCORING SUMMARY

Severity	Count
CRITICAL	2
HIGH	3
MEDIUM	2
LOW	3
INFO	5

5. PRIORITIZED REMEDIATION PLAN

Immediate (24–48 Hours)

- Add missing security headers
- Enable HttpOnly flag for PHPSESSID
- Remove users.sql immediately
- Hide server signature and PHP version

Short-Term (Within 1 Week)

- Implement CSRF protection
- Secure and relocate admin panel
- Replace or restrict FTP
- Add HSTS header

Medium-Term (Within 1 Month)

- Audit and close unnecessary open ports
- Implement login rate limiting
- Add CAPTCHA to login/register
- Create robots.txt

Long-Term

- Monthly security scans
- Quarterly penetration testing
- Developer security awareness training
- Develop formal incident response plan

6. SECURITY SCORE BREAKDOWN

Category	Score	Grade
SSL/TLS Configuration	95/100	A
Server Hardening	65/100	D
Web Application Security	60/100	D
Access Control	70/100	C
Data Protection	55/100	F

Overall Security Rating: 69/100 (D+)

7. CONCLUSION

While the SSL/TLS configuration is strong and modern, critical web application security issues significantly reduce the overall security posture of the system.

Immediate remediation of:

- Session cookie configuration
- Missing security headers
- Exposed sensitive files

is strongly recommended to reduce exploitation risk.

Assessment Conducted By:

PaballoFI Professional v3.0

Matsoso